

SESSION 11: Authorization

```
backend > app > models > user.py > {} enum
1 import enum
2 from sqlalchemy import Column, String, Enum, DateTime, Boolean, func
3 from sqlalchemy.orm import relationship
4 from app.database import Base
5
6
7 class Role(str, enum.Enum):
8     USER = "USER"
9     ADMIN = "ADMIN"
10
11
```

Hình 1: Các role có trong web

```
def get_current_admin(current_user: User = Depends(get_current_user)) -> User:
    if current_user.role != Role.ADMIN:
        raise HTTPException(status_code=403, detail="Not authorized. Admin access required.")
    return current_user
```

Hình 2: hàm kiểm tra role admin

```
46
47 @router.post("", response_model=dict, status_code=status.HTTP_201_CREATED)
48 def create_product(
49     product_in: ProductCreateUpdate,
50     db: Session = Depends(get_db),
51     admin: User = Depends(get_current_admin)
52 ):
53     # Tạo slug tự động từ tên (giản lược)
54     def slugify(text: str) -> str:
55         text = unicodedata.normalize('NFKD', text).encode('ascii', 'ignore').decode('utf-8')
56         text = re.sub(r'^\w\s-', '', text).strip().lower()
57         return re.sub(r'[-\s]+', '-', text)
58
59     slug = slugify(product_in.name)
60     existing = db.query(Product).filter(Product.slug == slug).first()
61     if existing:
62         slug = f"{slug}-{str(uuid.uuid4())[:8]}"
63
64     # Find or create Category - tìm bằng NAME trước (vì form gửi tên), rồi mới tìm bằng slug
65     category_id = None
66     if product_in.category:
67         cat = db.query(Category).filter(Category.name == product_in.category).first()
68         if not cat:
```

Hình 3: hàm tạo sản phẩm ở trang admin

```

@router.delete("/{product_id}", response_model=dict)
def delete_product(
    product_id: str,
    param admin: User=Depends(get_current_admin)
    admin: User = Depends(get_current_admin)
):
    product = db.query(Product).filter(Product.id == product_id).first()
    if not product:
        raise HTTPException(status_code=404, detail="Sản phẩm không tồn tại")

    db.delete(product)
    db.commit()
    return {"message": "Đã xóa sản phẩm"}

```

Hình 4: hàm xóa sản phẩm ở trang admin

Hình 5: role user không có quyền truy cập vào trang admin